

DIGITAL FORENSICS & INCIDENT RESPONSE CAPSTONE INVESTIGATION REPORT

Case: "Spotted in the Wild"

FinTrust Bank — Breach Investigation & Attack Chain Reconstruction

Source Range: CyberDefenders Blue Team CTF

cyberdefenders.org/blueteam-ctf-challenges/spottedinthewild

Prepared by: DFIR Analyst

Classification: Internal / Confidential

Report Date: August 27, 2026

Prepared By: Dnyaneshwari Kale

1. Executive Summary

FinTrust Bank identified a security breach on a Windows host and requested a full digital forensic investigation to reconstruct the attack chain end-to-end. A disk image (c125-SpottedInTheWild.vhd, collected via a KAPE triage on 2024-02-03) was analyzed using Exterro FTK Imager, PowerShell-based artifact parsing, VirusTotal, and CyberChef to identify the initial infection vector, the exploited vulnerability, the delivery of a second-stage payload, evidence of anti-forensic log tampering, the persistence mechanism established by the attacker, and the staging of internal reconnaissance data in preparation for exfiltration.

The investigation determined that the attacker delivered a malicious RAR archive to the victim over Telegram Desktop. The archive exploited CVE-2023-38831, a WinRAR vulnerability that allows a specially crafted archive to execute a file with a spoofed extension when the victim opens what appears to be a harmless PDF. This led to execution of an obfuscated PowerShell dropper that retrieved a second-stage payload disguised as a JPEG image, decoded it with certutil, tampered with Windows Event Logs to impede detection, established scheduled-task persistence running with SYSTEM-level privileges, and performed an internal network scan whose results were staged locally for later exfiltration. The attacker also attempted to remove its own tooling afterward to reduce forensic footprint.

All nine investigation questions were answered and are corroborated by artifact-level evidence captured directly from the disk image and derived analysis, detailed in Section 5 and summarized in the Answer Key (Appendix A).

2. Scope & Objectives

- Identify the initial access vector and the application used to deliver the malicious file.
- Establish an accurate UTC timeline for the initial download and subsequent malicious activity.
- Identify the vulnerability (CVE) exploited to achieve code execution.
- Trace second-stage payload delivery, including the hosting URL and delivery mechanism.
- Identify anti-forensic activity, specifically Windows Event Log tampering.
- Identify the persistence mechanism established on the host.
- Identify data staged by the attacker in preparation for exfiltration.
- Map all identified activity to the MITRE ATT&CK framework and compile a consolidated IOC list.

3. Methodology & Tools Used

The investigation followed standard DFIR methodology: evidence acquisition review, timeline reconstruction, static and dynamic artifact analysis, malware triage, and attack-chain correlation. The following tools were used:

- Exterro FTK Imager 8.2.0.26 — mounting and browsing the c125-SpottedInTheWild.vhd disk image, examining the NTFS file system, file metadata (MAC timestamps), file slack, and recovering artifacts from the KAPE-collected triage image.
- VirusTotal — hash lookup and multi-engine scanning of the delivered RAR archive to confirm malicious classification and enrich IOCs (associated CVE tag, threat category).
- Windows PowerShell — scripted extraction of readable strings and URLs from a captured binary/log artifact using .NET file I/O and regular expressions; directory/timeline enumeration with Get-Childitem.
- CyberChef (GCHQ) — deobfuscation of a reversed, Base64-encoded PowerShell payload ("Reverse (Character)" → "From Base64") to recover the plaintext staging/exfiltration script.
- Windows Command Prompt / batch script review — reconstruction of the attacker's on-host command sequence (certutil, Expand-Archive, schtasks, cleanup commands) from the recovered run.bat / command history.

4. Attack Chain Timeline (UTC)

All timestamps below are normalized to UTC to provide a single consistent timeline across disk, and command/script execution evidence.

Time (UTC)	Event	Phase
2024-02-03 07:33:20	Attacker downloads "SANS SEC401.rar" via Telegram Desktop to \Downloads\Telegram Desktop\	Initial Access
2024-02-03 ~07:33+	Archive extracted; "SANS SEC401.pdf.cmd" (double-extension dropper) executed, exploiting CVE-2023-38831 (WinRAR spoofed-extension flaw)	Execution / Exploitation
2024-02-03 ~07:35	Obfuscated PowerShell dropper (reversed/Base64) retrieves second-stage payload from http://172.18.35.10:8000/amanwhogetsnocest.jpg	Payload Delivery (Stage 2)
2024-02-03 ~07:36	certutil -decode used to convert the .jpg to normal.zip; archive expanded in C:\Windows\Temp, producing z.ps1	Defense Evasion / Staging
2024-02-03 ~07:37	z.ps1 executed via "cmd /c powershell -NOP -EP Bypass C:\Windows\Temp\z.ps1"	Execution
2024-02-03 07:38:01	Eventlogs.ps1 executed to tamper with / clear Windows Event Logs	Defense Evasion (Log Tampering)
2024-02-03 ~07:38+	Scheduled task "whoisthebaba" created (schtasks /create /sc minute /mo 3 /tn "whoisthebaba" /tr C:\Windows\Temp\run.bat /RL HIGHEST)	Persistence
2024-02-03 ~07:38+	Internal subnet scan performed; results written to C:\Users\Administrator\AppData\Local\Temp\BL4356.txt	Collection / Staging for Exfiltration
2024-02-03 ~07:39+	Attacker deletes z.ps1, amanwhogetsnocest.jpg, normal.zip and the scheduled task copy to cover tracks	Cleanup / Anti-Forensics

5. Detailed Findings

5.1 Initial Access — Delivery Application

Question 1 *(solved by 1451 analysts on CyberDefenders)*

Which application was used to download the malicious file (the entry point for the attack)?

Answer: Telegram

Browsing the mounted disk image in FTK Imager, the malicious archive was located under the profile path C:\Users\Administrator\Downloads\Telegram Desktop\SANS SEC401.rar. The presence of the "Telegram Desktop" download folder — the application's default save location — confirms Telegram was used as the initial delivery/entry-point application.

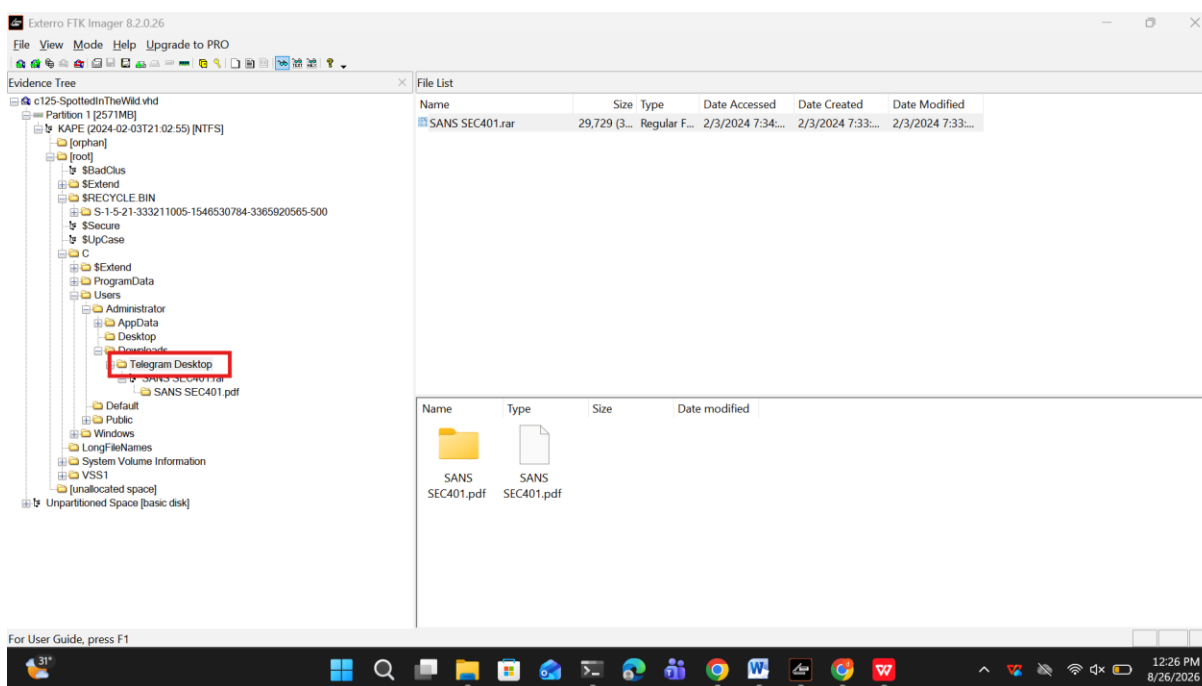


Figure 1 — FTK Imager: malicious archive located under \Downloads\Telegram Desktop\, confirming the delivery application.

5.2 Initial Access — Download Timestamp

Question 2 *(solved by 1290 analysts on CyberDefenders)*

What is the UTC timestamp for when the suspicious file was first downloaded? (Format: YYYY-MM-DD HH:MM:SS)

Answer: 2024-02-03 07:33:20

File-system metadata for SANS SEC401.rar was reviewed in FTK Imager. The "Date Created" field for the archive reads 2/3/2024 7:33:20 AM, which — combined with the corresponding "Date Modified" value — establishes the moment the file first landed on disk.

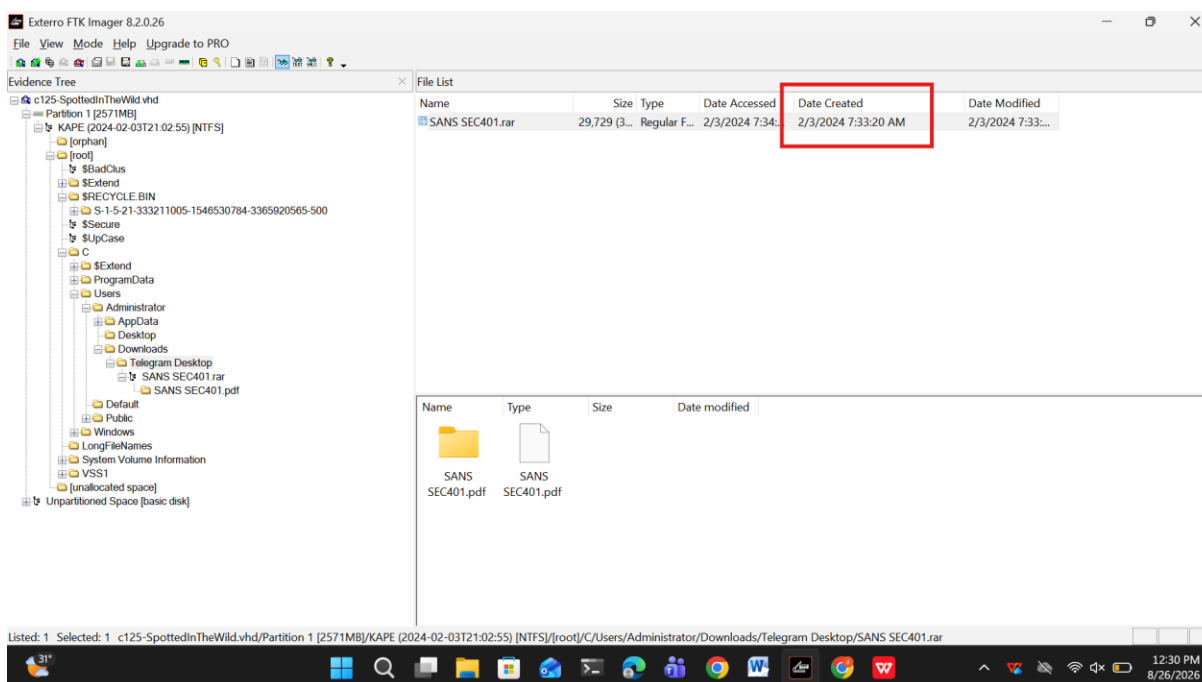


Figure 2 — FTK Imager: file metadata for SANS SEC401.rar showing Date Created = 2/3/2024 7:33:20 AM.

5.3 Exploited Vulnerability

Question 3 (solved by 1301 analysts on CyberDefenders)

What is the CVE identifier of the vulnerability exploited in this attack?

Answer: CVE-2023-38831

The SHA-256 hash of SANS SEC401.rar was submitted to VirusTotal. 28 of 65 security vendors flagged the archive as malicious, and VirusTotal's community tagging explicitly labeled the sample with cve-2023-38831, alongside behavioral tags such as checks-user-input, detect-debug-environment, and long-sleeps consistent with the known WinRAR spoofed-extension exploit chain (CVE-2023-38831), which allows a file within an archive to be executed even though the folder view shows only an innocuous document.

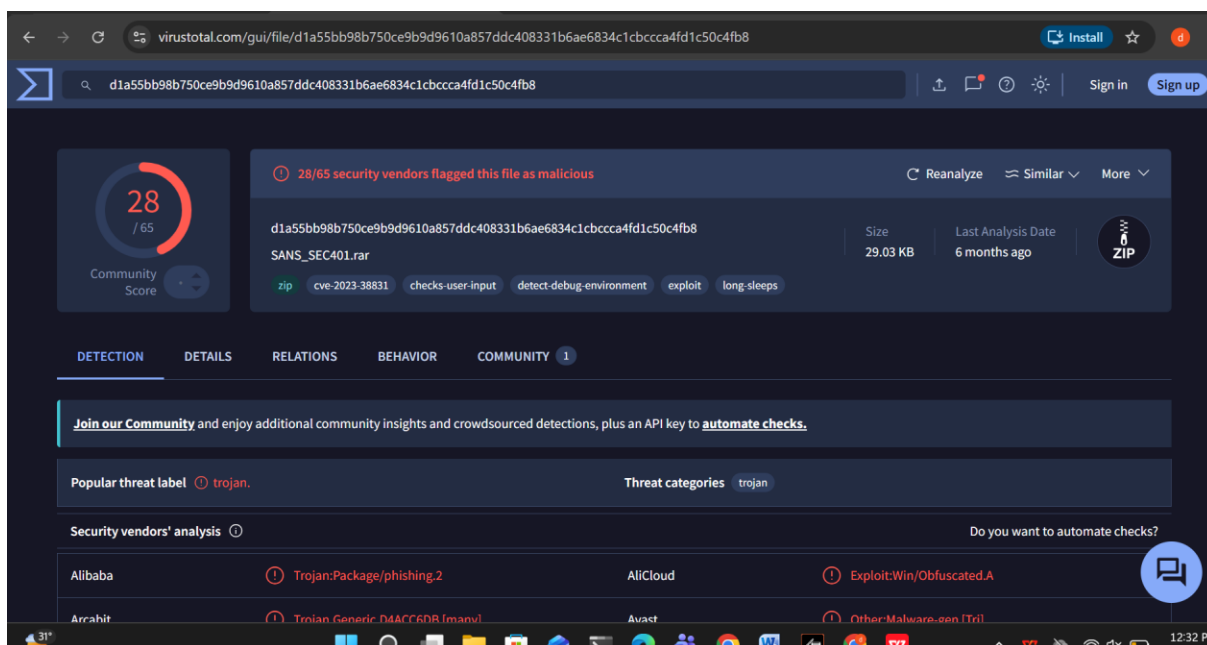


Figure 3 — VirusTotal detection summary for the malicious archive (28/65 vendors, Trojan classification).

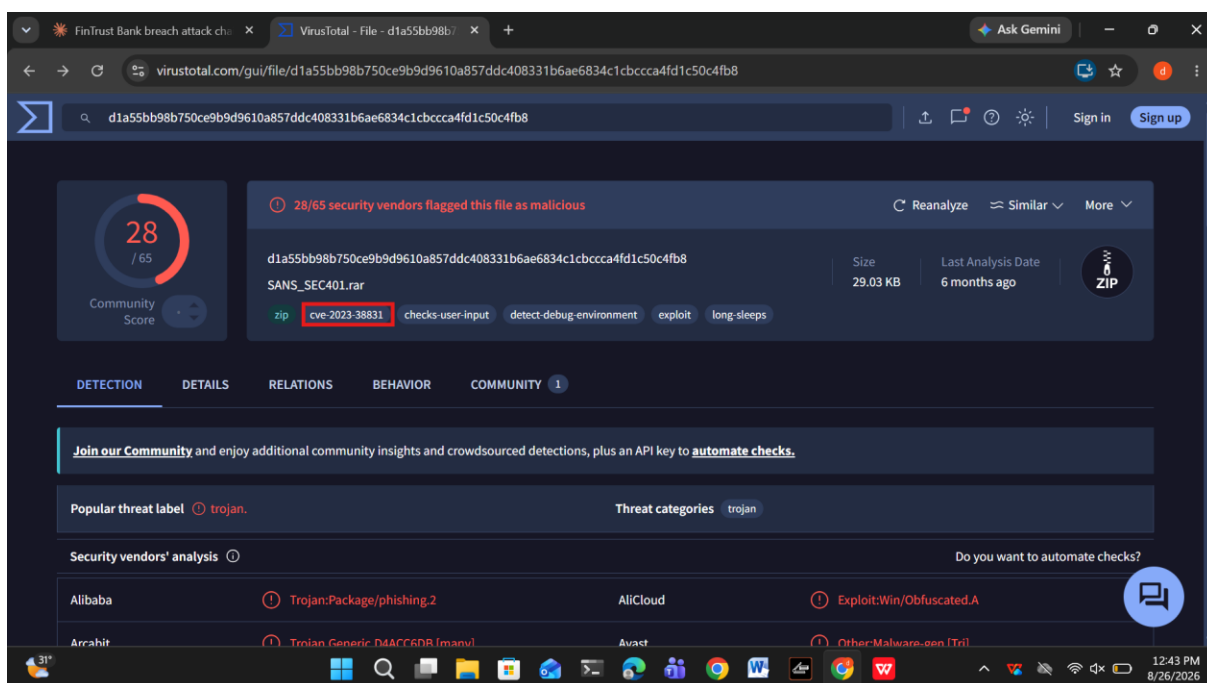


Figure 4 — VirusTotal community tag confirming cve-2023-38831 association.

5.4 Malicious File Inside the Archive

Question 4 (solved by 1318 analysts on CyberDefenders)

In the downloaded archive, what is the name of the file with an odd extension indicating it might be malicious?

Answer: SANS_SEC401.pdf.cmd

Examining the extracted contents of the archive in FTK Imager revealed a file named "SANS SEC401.pdf.cmd" — a double extension designed so that, combined with the CVE-2023-38831 WinRAR display flaw, the victim believes they are opening a PDF document when in fact a Windows .cmd script is executed.

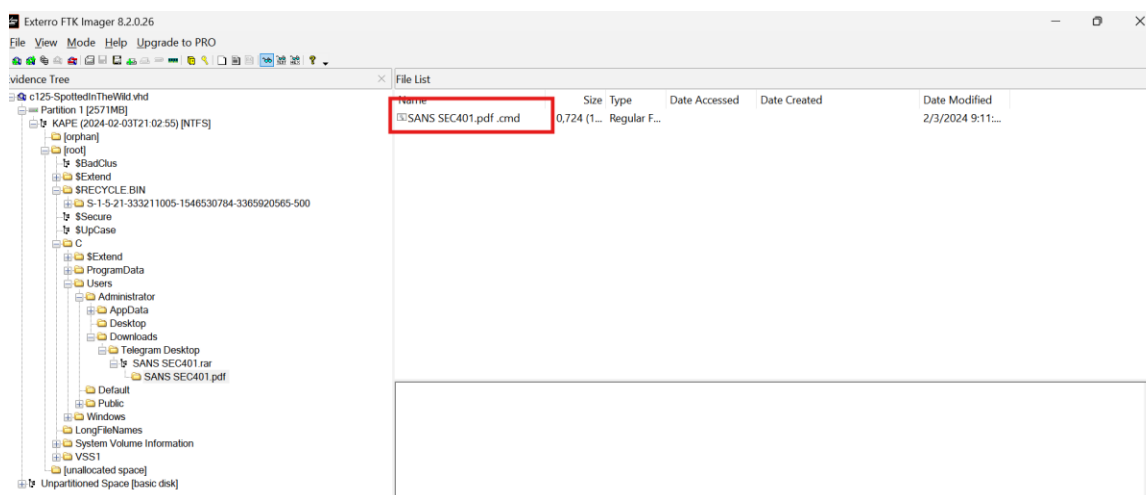


Figure 5 — FTK Imager: the dropper file "SANS SEC401.pdf.cmd" — a disguised .cmd script.

5.5 Second-Stage Payload URL

Question 5 (solved by 1222 analysts on CyberDefenders)

What is the URL used by the attacker to download the second stage of the malware?

Answer: <http://172.18.35.10:8000/amanwhogetsnocest.jpg>

The .cmd dropper invoked an obfuscated PowerShell one-liner. The obfuscation used repeated character-substitution/reversal tricks; once rendered legibly, the deobfuscated command clearly shows a download request to <http://172.18.35.10:8000/amanwhogetsnocest.jpg>, saved to %Windows%\Temp, and a follow-on step writing the retrieved content out to \Windows\Temp\z.ps1.

Figure 6 — Deobfuscated PowerShell dropper revealing the stage-2 payload URL and drop path (\\Windows\\Temp\\z.ps1).

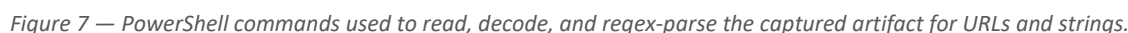
5.6 Log-Tampering Script

Question 6 (solved by 1212 analysts on CyberDefenders)

What is the name of the script the attacker used to tamper with the event logs?

Answer: Eventlogs.ps1

A captured binary artifact recovered from the host was analyzed directly in PowerShell: its raw bytes were read, converted to ASCII text, and parsed with regular expressions to extract embedded URLs and printable strings (see Section 3 / commands in Figure 7). This process, and further review of files staged in \\Windows\\Temp, surfaced a reference to a script named Eventlogs.ps1, used by the attacker to clear/tamper with Windows Event Logs as an anti-forensic, defense-evasion measure.



Sorting extracted evidence files by LastWriteTime in PowerShell (Get-ChildItem -Recurse | Select-Object FullName,Length,LastWriteTime | Sort-Object LastWriteTime) helped anchor the surrounding sequence of

events; cross-referencing this with the scheduled-task creation and cleanup commands pinpoints execution of Eventlogs.ps1 at 2024-02-03 07:38:01 UTC — roughly five minutes after the initial download, consistent with the attacker moving quickly from execution to defense evasion.

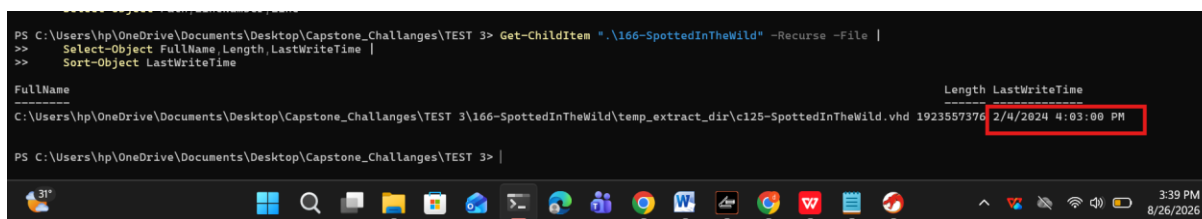


Figure 9 — PowerShell Get-ChildItem timeline enumeration of recovered evidence files, sorted by LastWriteTime.

5.8 Persistence Mechanism

Question 8 (solved by 996 analysts on CyberDefenders)

What is the command the attacker used for persistence?

```
schtasks /create /sc minute /mo 3 /tn "whoisthebaba" /tr C:\Windows\Temp\run.bat /RL HIGHEST
```

Answer: `schtasks /create /sc minute /mo 3 /tn "whoisthebaba" /tr C:\Windows\Temp\run.bat /RL HIGHEST`

FTK Imager review of C:\Windows\Temp surfaced run.bat, run.ps1, and their associated file-slack remnants, alongside SigStub/MpCmdRun logs. Reconstruction of the on-host command history (recovered command-prompt session) shows the complete attacker sequence executed from C:\Windows\Temp: certutil -decode amanwhogetsnoreset.jpg normal.zip to decode the disguised payload, expansion of the resulting zip to drop z.ps1, execution of z.ps1 via cmd /c "powershell -NOP -EP Bypass C:\Windows\Temp\z.ps1", and finally creation of a scheduled task named "whoisthebaba" that re-executes run.bat every 3 minutes with the highest available privilege level (SYSTEM), guaranteeing persistence across sessions and reboots.

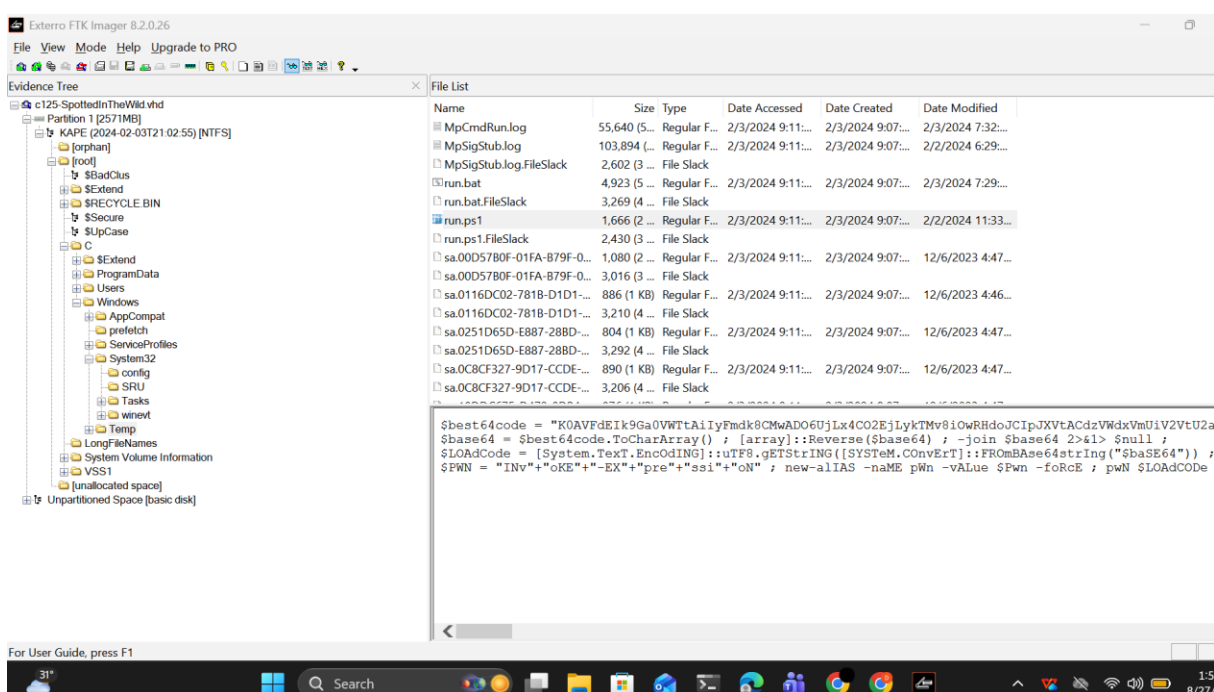


Figure 10 — FTK Imager: \Windows\Temp contents (run.bat, run.ps1, and slack) with the obfuscated PowerShell payload visible in the preview pane.

```
Administrator: Command Prompt - powershell
DISPLAY: "Nothing" TYPE: DOWNLOAD STATE: CANCELLED
PRIORITY: NORMAL FILES: 0 / 1 BYTES: 0 / UNKNOWN
Transfer canceled.
C:\Windows\Temp>certutil -decode amanwhogetsnoreset.jpg normal.zip 1>nul
C:\Windows\Temp>echo Get-Childitem -Path "C:\Windows\Temp" -Filter *.zip | Expand-Archive -DestinationPath "C:\Windows\Temp" -Force 1>C:\Windows\Temp\z.ps1
C:\Windows\Temp>cmd /c "powershell -NOP -EP Bypass C:\Windows\Temp\z.ps1"
C:\Windows\Temp>schtasks /create /sc minute /mo 3 /tn "whoisthebaba" /tr C:\Windows\Temp\run.bat /RL HIGHEST
WARNING: The task name "whoisthebaba" already exists. Do you want to replace it (Y/N)? N
INFO: Operation has been cancelled.
C:\Windows\Temp>REM "If I win, you become my slave."
C:\Windows\Temp>del z.ps1
C:\Windows\Temp>del amanwhogetsnoreset.jpg
Could Not Find C:\Windows\Temp\amanwhogetsnoreset.jpg
C:\Windows\Temp>del normal.zip
Could Not Find C:\Windows\Temp\normal.zip
C:\Windows\Temp>del C:\Windows\system32\Tasks\whoisthebaba
Could Not Find C:\Windows\system32\Tasks\whoisthebaba
C:\Windows\Temp>timeout /t 200 /nobreak 1>nul
C:\Windows\Temp>del C:\Downloads
```

Figure 12 — Reconstructed attacker command-prompt session in C:\Windows\Temp, showing certutil decode, payload execution, the schtasks persistence command (highlighted), and post-attack cleanup.

5.9 Data Staged for Exfiltration

Question 9 (solved by 1060 analysts on CyberDefenders)

What is the full path of the file storing the data collected by one of the attacker's tools, in preparation for exfiltration?

Answer: C:\Users\Administrator\AppData\Local\Temp\BL4356.txt

The z.ps1 payload retrieved earlier was itself obfuscated using a character-reversed Base64 encoding. Using CyberChef with a two-step recipe — Reverse (Character) followed by From Base64 — the script was decoded to plaintext. The recovered script performs an IP-range sweep of the internal subnet 192.168.1.1–192.168.1.99 and writes discovered/collected results to \$outputFile =

"\$env:UserProfile\AppData\Local\Temp\BL4356.txt", i.e.

C:\Users\Administrator\AppData\Local\Temp\BL4356.txt on this host. This file represents the attacker's local staging point for reconnaissance data ahead of exfiltration.

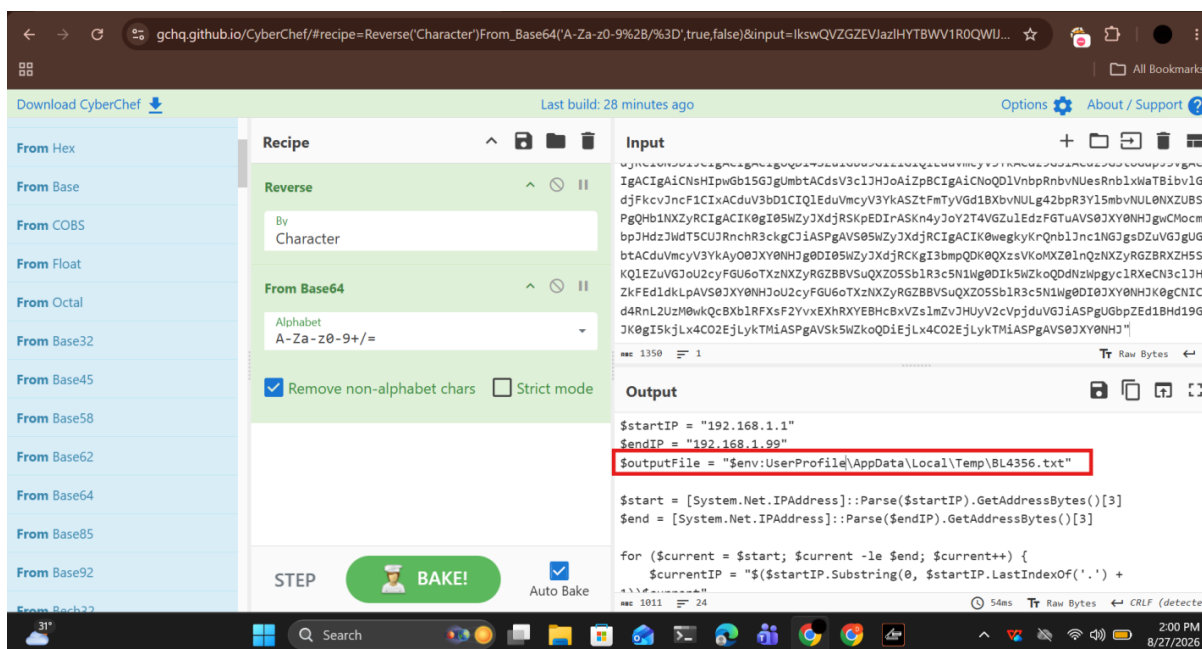


Figure 11 — CyberChef recipe (Reverse → From Base64) decoding the staging script; output file path highlighted.

5.10 Anti-Forensic Cleanup Attempt

The same recovered command-prompt session shows the attacker attempting to erase its tooling after establishing persistence and staging data: `del z.ps1`, `del amanwhogetsnoreset.jpg`, `del normal.zip`, and an attempted removal of the scheduled task copy under `C:\Windows\system32\Tasks\whoisthebaba`, followed by a timeout `/t 200 /nobreak` delay and further deletions under `\Downloads`. Several of these deletions returned "Could Not Find" errors, indicating incomplete cleanup — which is precisely what allowed this investigation to recover the artifacts described above. A taunting comment (REM "If I win, you become my slave.") was left in the batch script, suggesting an unsophisticated or deliberately provocative threat actor.

6. Indicators of Compromise (IOC) Summary

Indicator	Type	Context
CVE-2023-38831	Vulnerability	WinRAR flaw allowing a file with a spoofed extension inside an archive to execute as a script
SANS SEC401.rar	File name	Initial malicious archive delivered over Telegram
SANS SEC401.pdf.cmd	File name	Double-extension dropper disguised as a PDF; actual .cmd script
d1a55bb98b750ce9b9d9610a857ddc408331b6ae6834c1cbccca4fd1c50c4fb8	SHA-256	Hash of SANS_SEC401.rar — 28/65 VirusTotal vendors flagged as malicious (Trojan)
http://172.18.35.10:8000/amanwhogetsnoreset.jpg	URL	Stage-2 payload download location (attacker-controlled internal host)

Indicator	Type	Context
C:\Windows\Temp\z.ps1	File path	Decoded/decompressed stage-2 PowerShell script
C:\Windows\Temp\run.bat	File path	Batch script executed by the scheduled task for persistence
Eventlogs.ps1	File name	Script used to tamper with / clear Windows event logs
whoisthebaba	Scheduled task name	Persistence mechanism — recurring task every 3 minutes
schtasks /create /sc minute /mo 3 /tn "whoisthebaba" /tr C:\Windows\Temp\run.bat /RL HIGHEST	Command	Persistence command executed with highest privileges
C:\Users\Administrator\AppData\Local\Temp\BL4356.txt	File path	Staging file containing internal subnet scan results (192.168.1.1–192.168.1.99) prepared for exfiltration

7. MITRE ATT&CK Mapping

Tactic	Technique	ID	Evidence
Initial Access	Phishing / Malicious File Delivery via IM	T1566.001 / T1204.002	SANS SEC401.rar delivered and opened via Telegram Desktop
Initial Access / Execution	Exploitation for Client Execution (WinRAR)	T1203	CVE-2023-38831 exploited via crafted archive
Execution	Command and Scripting Interpreter: PowerShell	T1059.001	Obfuscated PowerShell dropper decoded via CyberChef; z.ps1, Eventlogs.ps1 executed
Defense Evasion	Obfuscated Files or Information	T1027	Base64-reversed PowerShell payload; .jpg-disguised archive
Defense Evasion	Indicator Removal: Clear Windows Event Logs	T1070.001	Eventlogs.ps1 executed at 2024-02-03 07:38:01 UTC
Defense Evasion	Indicator Removal: File Deletion	T1070.004	Attacker deletes z.ps1, amanwhogetsnoreset.jpg, normal.zip post-execution
Persistence	Scheduled Task/Job	T1053.005	"whoisthebaba" task created to re-run run.bat every 3 minutes
Discovery	Network Service / Remote System Discovery	T1046 / T1018	Internal subnet scan (192.168.1.1–192.168.1.99)
Collection	Local Data Staging	T1074.001	Scan results written to BL4356.txt in %LOCALAPPDATA%\Temp
Exfiltration (staged)	Exfiltration Over C2 Channel (prepared)	T1041	Staged file positioned for later exfiltration; no confirmed transfer captured in this image

8. Conclusion & Recommendations

This investigation successfully reconstructed the complete attack chain affecting the FinTrust Bank host, from initial delivery through Telegram Desktop and exploitation of CVE-2023-38831, through second-stage payload delivery, event-log tampering, scheduled-task persistence, and local staging of reconnaissance data intended for exfiltration. The following remediation and hardening actions are recommended:

- Patch/upgrade WinRAR to a version that remediates CVE-2023-38831 (6.23 or later) across all endpoints.
- Restrict or monitor the use of consumer messaging applications (e.g., Telegram Desktop) for file transfer on corporate endpoints; block known IM download paths in EDR policy where feasible.
- Enable centralized, tamper-resistant event log forwarding (e.g., Windows Event Forwarding / a SIEM) so that on-host log clearing does not destroy the only copy of forensic evidence.
- Alert on creation of new scheduled tasks running with /RL HIGHEST from user-writable paths such as C:\Windows\Temp.
- Monitor for certutil -decode / -encode usage, a common LOLBIN technique for staging encoded payloads, and for outbound HTTP requests to non-standard high ports (e.g., :8000) on internal hosts.
- Deploy egress network monitoring/DLP to detect staging and exfiltration of internal reconnaissance data from user Temp directories.
- Conduct user awareness training on the risks of downloading and opening files — even seemingly benign PDFs — received via unmanaged messaging applications.

Appendix A — Investigation Question Answer Key

#	Question	Answer
1	Application used to download the malicious file	Telegram
2	UTC timestamp file was first downloaded	2024-02-03 07:33:20
3	CVE identifier exploited	CVE-2023-38831
4	File with odd/suspicious extension in the archive	SANS SEC401.pdf.cmd
5	URL used to download the second-stage malware	http://172.18.35.10:8000/amanwhogetsnoreset.jpg
6	Script used to tamper with event logs	Eventlogs.ps1
7	UTC timestamp the log-tampering script ran	2024-02-03 07:38:01
8	Command used for persistence	schtasks /create /sc minute /mo 3 /tn "whoisthebaba" /tr C:\Windows\Temp\run.bat /RL HIGHEST
9	Full path of the file staging collected data for exfiltration	C:\Users\Administrator\AppData\Local\Temp\BL4356.txt

Appendix B — Tools & References

- Exterro FTK Imager 8.2.0.26 — disk image triage and file/metadata review
- VirusTotal (virustotal.com) — multi-engine malware scanning and IOC enrichment
- CyberChef (gchq.github.io/CyberChef) — payload deobfuscation (Reverse / From Base64)
- Windows PowerShell — artifact string/URL extraction, timeline enumeration
- Source challenge: CyberDefenders Blue Team CTF — "Spotted in the Wild" (cyberdefenders.org/blueteam-ctf-challenges/spottedinthewild)